

Business assets, supporting assets and DICT needs

✓ Giving a vocabulary to what the map must protect

Session objectives

By the end of this tutorial:

- **Define** business asset and supporting asset in the exact terms of the French reference method, and connect the two notions without confusing them
- **Translate** a business asset into security needs: availability, integrity, confidentiality, traceability, the famous DICT
- **Rate** these needs in relative position, without false precision, as the guide recommends
- **Assemble** for the MERIDIAN subsidiary under study by the working group, from its subsidiary pack, the exact material to be entered into the tool in the afternoon

Prerequisites

- This morning's lecture: the mapping, its stakes, its six views; the business view is precisely where this tutorial's notions live.
- The CISO's briefing: the inventory and critical assets; this tutorial gives "critical" a finer vocabulary.
- The subsidiary pack handed to the working group: the subsidiary's map of power (who decides what, who refuses what), the raw inventory as the subsidiary sent it to the Group CISO, the diagnostic findings that concern it, what crosses its boundary. The three exercises are done on this pack, not on the group's reference dossier, which only serves to place the subsidiary among the others.

✓ The missing presentation: four notions, in the order they chain together

A quarter of an hour of vocabulary before handling anything, and this vocabulary is that of ANSSI's EBIOS Risk Manager guide, version 1.5, September 2024, whose risk assessment method arrives in sessions 5 and 7. Today the session borrows only its glossary, because mapping and risk analysis share these words, and learning them once is enough.

The problem this vocabulary solves: "critical asset", the morning's notion, mixes two questions the method separates. What matters for the mission? And what does it rest on technically? As long as the two are not separated, business and technology fight over the same list: the doctor puts "patient records" on it, the administrator puts "the DBMS" on it, and both are right without understanding each other. The method settles it by giving each a word.

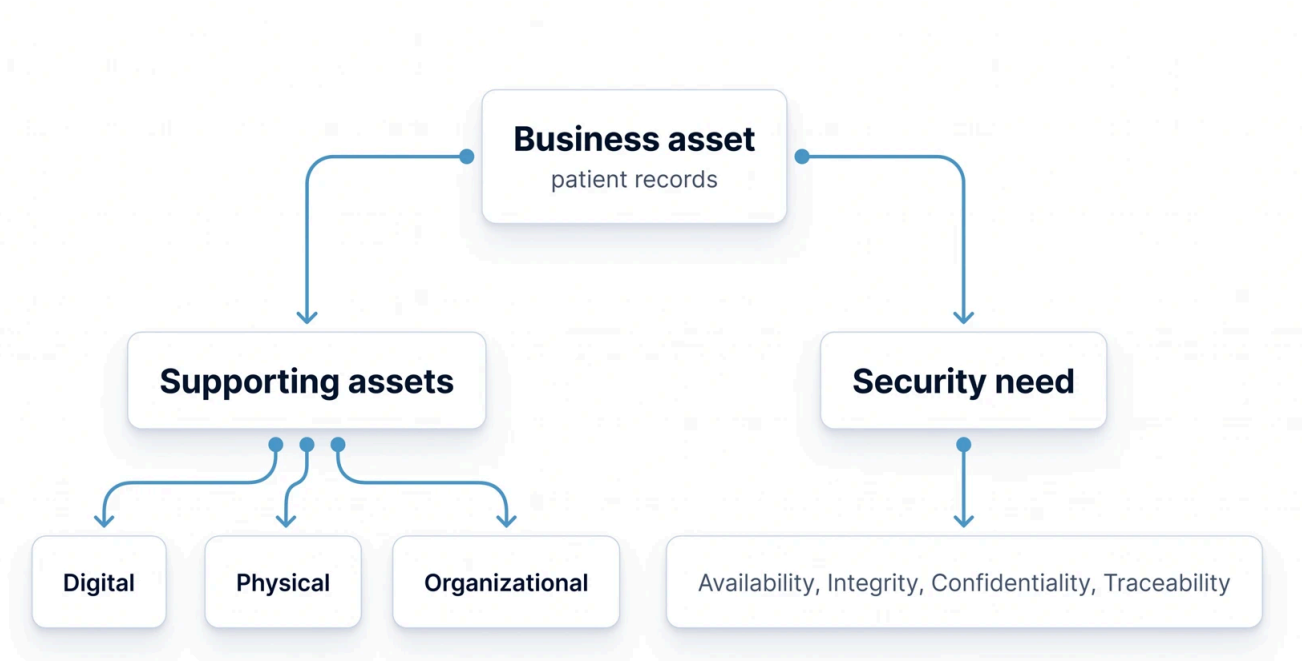
The business asset, first, defined by the guide's glossary: « Dans le cadre de l'étude, composante importante pour l'organisation dans l'accomplissement de sa mission. Cela peut être un service, une fonction support, une étape dans un projet et toute information ou savoir-faire associé. Une valeur métier peut être vue comme un élément à protéger. » ("Within the study, an important component for the organization in the accomplishment of its mission. It can be a service, a support function, a stage in a project and any associated information or know-how. A business asset can be seen as an element to protect.") This is the answer to the first question: what matters. The guide gives telling examples of it, an online booking cancellation service, customer information, research results. What the definition does not contain: a single technical word. A business asset is phrased in the language of the business, and a list of business assets that looks like a list of servers has already slipped from one question to the other. A landmark of normative archaeology, because these synonyms run through an entire career: the ISO 27005 standard calls this « biens primaires » ("primary assets"), and the old 2010 EBIOS method said « biens essentiels » ("essential assets").

The supporting asset, next: « Composante du système d'information sur laquelle repose une ou plusieurs valeurs métier. Un bien support peut être de nature numérique, physique ou organisationnelle. » ("A component of the information system on which one or more business assets rest. A supporting asset can be digital, physical or organizational in nature.") This is the answer to the second question: what it rests on. The guide's examples deliberately sweep the three natures: a server, a telephony network, an interconnection gateway, but also a technical room, and even a team or administrators. This breadth matters: a supporting asset is not necessarily a machine, and forgetting organizational supporting assets, the only team that knows a system for example, is exactly the hole diagnosed at Logistique in the morning. The guide also defines the **critical supporting asset**, the one judged highly likely to be targeted by a risk source: an expression to keep in reserve, it will take on its full relief with the scenarios of sessions 5 and 7.

The security need, finally, and this is where the acronym in the title lives: « Propriété de sécurité à garantir pour une valeur métier. Elle traduit un enjeu de sécurité pour la valeur métier. EXEMPLES : disponibilité, intégrité, confidentialité, traçabilité. » ("A security property to be guaranteed for a business asset. It reflects a security stake for the business asset. EXAMPLES: availability, integrity, confidentiality, traceability.") Four properties, four initials:

DICT, from the French words. Two points of terminological honesty. On the one hand, DICT is a professional shorthand, convenient and universally understood, but the method's term is « besoin de sécurité », the security need: in a formal dossier, the term is written out in full, the acronym is kept for speech. On the other hand, the ISO 27005 standard says "security objectives" for the same idea, and the afternoon's tool "security targets"; the same family of synonyms as before. What the security need is NOT: a property of the machine. It is the business asset that needs availability or confidentiality, and the supporting asset inherits it; reversing this direction, rating servers instead of rating what they carry, is the most frequent error of the coming exercise.

The complete chain fits on one line, which is also the order of the three exercises: the organization's mission designates its business assets; each business asset expresses its security needs; each business asset rests on supporting assets, which must guarantee those needs. When harm strikes a need of a business asset, unavailability of a service, disclosure of information, the method speaks of a feared event; that notion belongs to session 5, but one exercise already shows what it looks like in real life.



One last tool before starting: **rating**. The guide recommends classifying needs as « très importants », « notables » or « négligeables » ["very important", "notable", "negligible"], or on a 3 or 4-level scale, and it specifies the objective: obtaining « une position relative des valeurs métier les unes par rapport aux autres » ["a relative position of the business assets with respect to one another"]. Relative position: those two words protect against the exercise's infantile disease, false precision. A 3-level rating the team understands is worth more than a mark out of 100 nobody can justify; what is asked is being able to say WHY the availability of freight weighs more than that of the training portal, not producing decimals.

The guide's own running example serves as a model answer key: a biotechnology company, a vaccine manufacturer, whose business assets and supporting assets the guide walks through. It is to be consulted in case of doubt about method: it is the official yardstick for the exercise now conducted on MERIDIAN.

💡 A quick test to separate business asset from supporting asset: "would the business weep over its disappearance, or only the IT department?". At TRAMONTANE, the fictional online retailer of outdoor equipment that serves as the example outside the pack throughout the module, the customer orders in progress make customer service and the sales director weep; the database server hosting them only makes the administrator weep, precisely because it can be replaced by another. The former are a business asset, the latter a supporting asset.

✓ The worked example: the complete chain at TRAMONTANE

Before MERIDIAN, the complete chain on a case taken outside the pack, so as not to give away the exercises. TRAMONTANE, the fictional online retailer of outdoor equipment introduced above: an e-commerce site hosted by a cloud provider, a warehouse in Rivesaltes run by a warehouse management system published by a third party, a payment service provider, a carrier linked by electronic data interchange, an IT department of twelve. Its mission fits in two verbs, sell and deliver, and three business assets are enough to show the mechanism.

Business asset	Nature	Security needs, rated on three levels	Justification of the dominant rating
Online order taking	Service	Availability very important; integrity notable; confidentiality notable; traceability notable	Site down, the retailer no longer sells: unavailability is counted in revenue lost per hour
Customer and payment data	Information	Availability notable; integrity very important; confidentiality very important; traceability very important	An altered address sends the parcel elsewhere; a disclosure engages the retailer's liability and its relationship with the payment provider; one must be able to say who consulted what
Picking and shipping of orders	Service	Availability very important; integrity very important; confidentiality negligible; traceability notable	A warehouse at a standstill means selling what cannot be delivered; a falsified stock means promising what one does not have; knowing who picked what mostly serves disputes

Then the supporting assets, attached to what they carry, deliberately covering the three natures:

Business asset	Digital supporting assets	Physical supporting assets	Organizational supporting assets
Online order taking	The e-commerce site and its database; the gateway to the payment provider	The cloud provider's servers; the head office's network link	The IT department's web team, three people; the hosting contract and its availability commitment
Customer and payment data	The customer database; the provider's payment module	The same hosted servers; the customer service workstations	The payment provider; customer service, which handles this data over the phone
Picking and shipping of orders	The warehouse management system; the picking terminals; the data interchange with the carrier	The Rivesaltes warehouse, its conveyors, its network link	The warehouse system's publisher, in remote maintenance; the team leader who alone knows the settings

Three lessons to carry into the exercises. Relative position, first: order taking and customer data are not rated the same, and that is what ranks them; if all three rows showed "very important" everywhere, the table would have said nothing. The direction of the rating, next: it is the orders that require availability, and the hosting provider's servers inherit it; nobody rated a server. The same supporting asset, here the hosted servers, in fact carries two business assets and inherits the more demanding need of the two: that is how a supporting asset becomes critical, by what it carries, never by what it costs. Finally, the feared event as a preview: if the customer database were consulted by a third party, the harm would strike the confidentiality of a business asset, with notification to the supervisory authority and loss of customer trust; described with today's words, it is what session 5 will name and learn to rate.

Exercise 1: the business assets of the subsidiary under study

Each working group studies ITS subsidiary, from the subsidiary pack it was handed: its map of power, the raw inventory as the subsidiary sent it to the Group CISO, the diagnostic findings that concern it, its constraints, what crosses its boundary. Two groups study the same subsidiary without conferring; the confrontation comes in the afternoon. The raw inventory mixes services, information, equipment, people, sites and providers, with no label and no classification: that is deliberate, it is how it arrives in real life.

1. **Identify** between three and five business assets of the subsidiary under study, phrased in the language of the business, limiting yourself to what the subsidiary pack establishes (hint: also think of information and know-how, not only of services rendered).
2. **Attach** to each business asset its supporting assets, making sure to cover the three possible natures, digital, physical, organizational; the raw inventory contains some of each nature, but none is labelled. Name for each

business asset the function that answers for it, from the map of power in the subsidiary pack: it says who decides what, it does not say who protects what.

3. **Spot** in the list the supporting asset that the diagnostic findings make the most worrying for this subsidiary, and justify in one sentence why, with the vocabulary of this tutorial and not that of the audit.

Suggested time: 12 minutes. Output: a two-column table, business assets and supporting assets, ready to be entered as is this afternoon.

✓ Exercise 2: rating the DICT needs, calibration by facts

Here are four real facts, each illuminating one of the four properties. At the Centre Hospitalier Simone Veil in Cannes, in 2024, ransomware encrypted 15 % of workstations as well as a file server: caregivers deprived of their working tools, that is what "availability" means. In January 2026, the CNIL imposed 42 million euros in fines on Free and Free Mobile after the October 2024 intrusion that had allowed the data of 24 million subscriber contracts to be viewed: confidentiality, and its price. At France Travail, in 2024, it was the data of 43 million people that was potentially exfiltrated: the scale that harm to a single business asset, user data, can take. And according to ENISA, in 2024, 32 % of European operators in the energy sector had none of their critical operational technology processes monitored by a security operations center: traceability absent from an industrial world, the very one in which Logistique's automated warehouses operate.

15 %

OF WORKSTATIONS ENCRYPTED BY RANSOMWARE
AT THE CANNES SIMONE VEIL HOSPITAL:
AVAILABILITY

Cannes hospital, 2024

€42M

IN CNIL FINES AFTER THE INTRUSION THAT
EXPOSED 24 MILLION SUBSCRIBER CONTRACTS:
CONFIDENTIALITY

CNIL, Free and Free Mobile, January 2026

43M

PEOPLE POTENTIALLY AFFECTED BY THE
FRANCE TRAVAIL EXFILTRATION: THE SCALE
HARM CAN TAKE

France Travail, 2024

32 %

OF EUROPEAN ENERGY OPERATORS WITH NO
MONITORING OF THEIR CRITICAL OT
PROCESSES: TRACEABILITY ABSENT

ENISA, 2024

The work bears on the subsidiary under study, with the business assets from exercise 1.

1. **Keep** two of the business assets identified in exercise 1, the two that seem the most contrasting.

2. **Rate** the four DICT needs of each on the guide's three-level scale, in relative position, with for each rating a one-line justification anchored in the subsidiary's business (hint: what stops the activity, what falsifies decisions, what interests a third party, what prevents understanding an incident afterwards).
3. **Compare** the ratings between the two business assets and against one of the four calibration facts: which rating would deserve revision if the ranking had to be defended before the subsidiary's director, and why?

Suggested time: 15 minutes. The rule of the game: no rating without justification, and no row where everything would be "very important", because a rating that gives nothing up is not a rating.

✓ Exercise 3: the complete chain on an inter-subsidiary dependency

Each subsidiary pack describes, in its section "What crosses the subsidiary's boundary", a dependency on which the synthesis exercise bears. For the Santé and Logistique groups: emergency supply, where Logistique's warehouse handheld scanners feed Santé's inventory management system, through a supply API on a dedicated VLAN with an inspection firewall, a flow blocked for three months at Santé's request. For the Éducation and Territoires groups: the identity directory shared by the division, run by the pooled IT department, on which the teaching portal rests on one side and the citizen services platform on the other, with administration accounts shared between the two subsidiaries.

1. **Walk through** the complete chain of the vocabulary on the subsidiary pack's dependency: the business asset concerned (who owns it, by the way? The pack's map of power gives only half the answer, the half of the subsidiary under study), its rated DICT needs, and its supporting assets, including those one forgets and those living in the other subsidiary.
2. **Describe**, without using session 5's technical term, what would happen if the integrity of what passes through this dependency were altered, stock data on one side, accounts and rights on the other: it is the first encounter with what the method will call a feared event.
3. **Explain** in two sentences why this case justifies a group-level map and not only four subsidiary maps.

Suggested time: 10 minutes. This is the synthesis exercise: it mobilizes the three notions and directly prepares the internal ecosystem view entered in the afternoon.



Answer keys and assessment criteria — cliquer pour révéler